京东

网络安全工程师 - JDY 事业部

1. 一面

1. Q：目前在学校主要做什么呢?
   A：目前在学校的话就是我毕业论文这边的方向，就是我目前打算做的就是一个。因为现在人工智能比较厉害，就是我想的是因为我们传统的waf它可能是基于规则的一个拦截，但是它规则毕竟是比较死的。所以我想的就是利用深度学习，它可以发掘到一些我们就是从业务层面上它难以发觉的一些关系。去去寻找去寻找他那个通流量过来之后，可能潜藏的一些目前规则检测不到的一些威胁。因为深度学习他是黑盒的，所以说有一种我们察觉不到的这种可能的一些威胁。然后他去做了一个检测过后，然后他会把一些可能他自信的一些，因为他是分类，根据这个HTTP 报文进行分类，分类的话它有一些置信度。根据这个置信度，然后就是去后面传到一个大模型，或者是用传到agent这样子让他们去拿到这个原数据之后，去考虑对规则进行一个优化或者是生成这样子然后再反哺到原先的现在的这个，企业运用到waf上面。
   就是因为考虑到它现在大模型，它，不是大模型，就是前面

的一些分类检测，它可能的性能并不能做到完全的实时。所以说目前是做一个依旧是做一个类似于分流分级的一个一个是这种架构。就是先常用的一些规则去做一个比较基础的一些规则，那个就是威胁的检测，然后他就是这样子去通过结合AI和深度学习去暂时提高他这个规则的一个能力。

2. Q：结合AI和深度学习，像AI主要是对比如说现有规则进行一个优化，就是你比如说他可能有一些污染机的情况，然后人工进行一些打标，让他去优化吗？还是？
   A：可能我目前这边，因为我现在还在开题的摸索阶段。目前大部分他们都是通过偏数学上的一些方法，然后去用多个agent的这种结合去做一个把完全把这个规则优化去交给大模型来做一个处理。然后至于出来的结果其实可以人工进行去去介入，去再回查一下他是否能否满足目前的需求。

3. Q：这里面如果是说实际去落地的话，可能会遇到一个问题，就是waf其实是有拦截能力的那如果直接比如说这个全交给大模型，他万一就是生成的规则比较宽泛一些，影响到线上业务。这种情况不知道应该基于比如说从落地的角度去考虑的话，你觉得应该怎么去尽量避免或者说减少这个场景的发生？
   A：第一个的话，我想的就是兜底的方案，因为很多现在都是目前我所学学习过的一些技术站，这些他们都会有至少有一个兜底方案。就比如我刚刚所说的，你规则生成之后，可能人工需要去介入一下，就是去看去做一个兜底，看他是否有没有这种误拦截的情况。比如说前面一些正常的 SQL 的一些业务，这些过来如果他误拦截了，可能会导致线上的一个情况，就是查询不到，会影响到核心业务。这个可能就是需要

人工去做一个兜底的。然后的话如果说他线上就是你不放心的话，可以自己去。我想的可能是提 prompt，就是再和大模型去做一个交互。根据你可能这些实际的情况，把一些比如说我不能这个可能限制太死了，或者说觉得他不够泛化，就是再和大模型去做一个交流，然后再去改进。这是我目前可能想到的这两种情况。

4. Q：AI在那个安全的场景里面，因为您刚刚提到的，我感觉像是主要是在这个产品的优化，那有没有其他方向都没有想过。

   A：前我前两天看到一个一公众号，它是一个自己去做了一个 agent 然后去打一个CTF。就是说他是写了一个写了用了两个 agent 然后去调 MCP。然后它就首先它是两个 agent，一个是做一个决策。然后第二个就是一个具体的一个攻击手。然后他就是因为因为他这个呃呃单独分出来一个决策，是考虑到他的一个目前大模型的一个缺陷，就是它的上下文还是不够的，充裕可能会有一些遗忘的这种状态，就是会有一个决策。

   然后接下来就是一个攻击手，攻击手的话因为他就是去执行具体的一个解题。然后他调用了MCP。MCP的话他做的比较简单，就是把咖喱的咖喱把它用docker然后去把它包装成MCP的一个服务器。然后还有一些其他的一些零星的工具去做一个包装，然后就是用一个这样的整体架构去让他去打CTF。

   然后我现在想的就是我看这个项目，我就是想能不能去做一个做一个实际应用上面的一个扩展。比如说我们实际上打

CTF，它只可能是只针对一道题，或者说当前的一些特殊的情况。那我想的是如果说我们基于外部渗透的话，我肯定把它宽放到一个打点，就是把它去换化到一个我们实际做渗透的一个情况。这样子的话我其实也在构思，因为他他那个项目用的是一个python的long chain，然后我这边其实主要最基础的是java。

然后我就想因为正好学了spring AI阿里巴巴的一个框架，然后我就是想着就是我能不能按照他这个思路，比如说我也去做一个决策层，同样也是避免一个上下文的一个缺陷的问题。至于打点，它因为它只用了一个agent去做。但是实际上我们是web的渗透，它分为打点信息收集。信息收集之后，我要根据他的具体的信息，然后我去做一些通用的渗透。比如说他有一个 SQL 注入，或者说 SSRF 这些可能一些敏感的地方。然后接下来或者说他可能用了一些主页，可能需要去调一些漏洞，用 CVE，这可能还需要一个agent，就是用多维性的多个工具步骤要交给不同的agent，而不是只交给一个。

最后实际渗透业务中，他可能还需要一些报告的生成去做一个报告的生成。可能说你参与的一些甚至测试，他们可能需要如果就是我就是从相当于从运营的一个思路去走了，就是简化一下这个工作的一个压力，就是去做一个自动化的一个报告生成，这可能也额外需要一个。然后我就是目前有这样的一个想法，然后主要的这个决策的agent他可能去去决策的过程中，他可能就是说在设计一个兜底机制。比如说打了一下，那他打了可能尝试了三遍或者几遍以上，他可能并没有

说拿到一个入口。
这个时候我可能需要他把一个他的渗透的思路返回过来，然后我再去做一个人工的去做一个介入，去做一个他的一个思想的改变。就是比方他这个攻击的一个agent，就是防止他的一个思维固化的一个情况。这是目前word的一个思路，然后的话可能会考虑到一个云上的一个情况。但是我云学的不学的并不是那么的深入。就是想到可能现在目前有一些云渗透的一些框架，渗透攻击框架可能CF像这样的，就是说我考虑也可以去拓展到一些云上的一个情况。

5. Q：那云原生有什么安全问题吗?
   A：我目前了解到的会有一些容器的一个逃逸的一些情况。然后他可能会有一些比如说一些对象存储，它可能会存储在一个云上，比如说 Minio 这种，他可能会有一些bucket 在上面，就是说会有一些这种渗透的情况。比如说接桶的接管，还有这种存储钥匙存储钥匙的泄露这样的。

6. Q：关于AI本身的安全有了解过吗?
   A：这个之前有过一些了解，主要是可能是我目前只是稍微了解过两个方面。一个就是他数据的投毒，就是可能因为在一训练的一个情况，他他的数据有可能去做一个做对他做一个下手。比如说我把一些可能是攻击payload的这种原数据，我把它把从恶意改成良性。这样子的话他可能为我为以后他那个渗透，他可能就是我这个流量供这个流量过来。他可能就是因为之前在他训练数据堕落手脚，他可能在这方面就他就被放过去了。
   然后第二个就是一个提示词注入，就是可能会有一些越狱去

见你，比如说直接的你让他去忘掉他的一个system prompt，或者说间接的。比如说让他访问一个网页，那个网页里面我可能里面去塞一些提示词，就是这样子去间接的让他做一个粤语。比如说在在那个网页里面，就是说让他忘记一些什么，忘记系统提示，这样去做一个渗透。然后最后的话可能。

暂时还有一种可能就是他的注意力就可能是在之前的一些大模型会有一些情况，可能他注意力就是上下文还是是不够长的。当你重复的输入一些大量的内容，我们会让他做成一些遗忘。可能在一些企业的自己不大模型的时候，它可能会有一些可能它基于一些敏因一些敏感的隐私信息，可能会在上下文这种遗忘了之后可能会泄露出来。然后就是目前我了解过就是这些。

7. Q：传统的安全问题，比如说 SQL 注入，防御方案是什么？
   A：目前从开发的角度来讲的话，我在写代码的时候尽量去用一些预编译的手法去做。比如说prepare statement，然后或者用 MyBatis 的一些的那个井号的一个井号加大括号的一个情况去去预编译。然后至于 order by 后面的那种动态注入的情况，就是需要开发上面可能会去让他去做一个白名单。比如说我数据库里面有多少个字段，有什么字段我就从这个白名单里面去取，或者说可以调像PHP，它可能会有一些转移字符，或者说我白名单就限制了你不能有一些特殊的字符，单引号、双引号这些，你只能英语数字字母。这种情况用黑白名单的一个方式进行一个处理。
8. Q：对于像有些大数据类型的业务，它可能本身就需要通过接

口传 SQL 语句。在这种场景下有没有什么方案能尽量保证这个业务的安全?

A：我想的可能首先就是还是先从业务的上面去考虑。比如说我这个大数据去查询的话，有一些比如说增删改的一些关键字。如果说这个业务它实际上并不涉及的话，去做一个就是做一个这种危害性的一个缩小。如果说如果就是做一个兜底，就是说如果出现了一些紧急情况，不至于将它的危害扩大。然后至于查询的一个内容的话，我刚才想的就是可能还是业务它上面业务它本身就是有多少个表，其实这个公司里面是知道的。但是如果你出现了，他查了一些疑问，其他额外的一些内容不存在的表，或者说他查了一些敏感的一些表。比如说mysql他们的那个information schema的那个表，你不能让他查。这是做一个就是说我查的一个来源，必须是他们。

9. Q：一些逻辑问题有没有了解过，像水平和垂直越权的问题。

   A：主要是可能是指水平越权和垂直越权的两种情况，水平越权的话，之前，有尝试挖过相关的漏洞。可能主要是因为常见的情况，我比如说访问一些订单号，一些可能通过一些ID去访问的。然后他这个ID实际上他并他在开发设计过程中，其实他就不规范。我们常见的一些是通过UUID的，就是雪花算法去做，这样就比较安全，就是不会去猜到另外一个订单的它的一个大概的可能ID号。但是如果是基于big item或者是big item的那种设计方式，或它会有一种很规律的一个自增型，这样子的话就会再加上他的一个鉴权，他并没有做一个就是你可访问的一个这个范围。它可能就是会造成一个水平

越选的一个情况，就是我可以我会访问我不我不不应该访问的内容，垂直越权的话。呃。这个我只停留在理论方向，就是没有去做过，尝试去挖过这些就这样。

10. Q：那对于比如说转账的这个场景可能会有什么安全问题？（卡了之后提示：比如从事物的一致性考虑。）
    A：事物的一致性考虑的话，可能就是涉及到mysql的事物的话，它可能会有一个读会有一个从...
    Q：脏读脏写有了解过吗？
    A：脏读它可能是可能在多线程的一个情况下，就是一个他可能做了一个变动，比如说去修改了。但是因为他可能是读未提交的情况下，把别人因为他可能一个事物过程中他读未提交，就是我读到了别人还没有commit的一个修改情况。可能就是会造成一个比如说金额上的一个就是非预期的一个变动，可能会重复的加减。
    Q：那这里面会有什么安全的原因吗？
    A：如果说他这个事物存在这种情况，并且它的接口没有做做鉴权的话，那可能他通过的重复提交数据包的话，就会导致他的一个金额会无限的增加或者减少。是这样吗？
    这种情况下可能就会去做一个多次请求，可能会之间会做一个时间限制，类似于我想可能会类似于验证码这样的一种情况，不能让他连续的短时间内并发多次的这个请求。

11. Q：再比如说可能会有一个场景，因为我们常遇到的像打卡签到，然后他会有一些奖励。然后在这个场景之下，如果是高并发厂去请求会有什么安全问题？
    A：打卡的情况，我如果从攻击方的角度，我可能会要这种我

可能会尝试用 Burp 去做一个快速的并发。它这样子的话它的积分就是因为在在短时间内大量的时可能在很短的时间内会有大多个相同的请求过来。然后他如果没有做一个原子性的判断，他可能就是会短时间内，比如说签到，他可能会加三点积分。如果你一次性并发十条数据过去的话，他可能会有会加30分，就是会有这样的一个逻辑漏洞的情况。

Q：然后针对这个问题应该怎么去修复，有了解吗？

A：在 Go 中有single flight的单飞机制，就是可能会让多个请求上锁，最后只让一个请求过来。再就是根据业务情况，比如说我会加一个类似的所释放的一个时间，可能我短时间保证它不会有多个并发的请求过来，直到业务中能够保证它这个事物完成，保证他这个事务完成。比如说每天只能签到一次，我保证他这个整体签到成功，并且数据库字段发生改变，确定他那个字段是已签到这种情况之后，然后这样子的话就是有一个这样的时间的机制，保证它不会出现这样的问题。通过上锁加上时间的机制。

12. Q：您对java比较了解是吗？是因为安卓就有了解吗？

    A：以前写过一些玩儿，就是写一些NFC的一个小工具，这样学了一点安卓，但是没有很亲近，用的是还是java，也没用 Kotlin 去写。

13. Q：那四大组件的activity是什么知道吗？

    A：Activity 是一个页面的，我印象中是一个页面的一个，就是生命有个生命周期。然后他大概是有七个，包括他的点击，创建前和之中，还有之后他会做一个有个七大这个时间就是函数这样。

14. Q：Activity有什么安全问题有了解吗?
    A：这个我就没有去了解了。
    Q：那客户端的安全问题，也不太了解?
    A：是

15. Q：您现在是在学校是吧？实习的话，大概什么时候可以到岗？然后大概能实习多久？
    Q：行，我暂时没什么要问您的了。你看有什么要问我的吗?

16. 反问 Q：我想问的就是您说您我了解到您这边是一个云京东云上的一个部门。我想我想问的是您这边会涉及到云上的一种，就是我了解到有云上的一个安全的一些工具，比如说 Falco 这种，CNCF这种，这种安全的一些工这种组件或者是工具啥的。就想请问你们这边业务会涉及到这些吗？就是我因为我在学校中，我不太能接触到云上的这些业务，就是想了解一下。
    A：然后云底层的话都是用的像 k8s，docker还有一些就是想您在使用那个，比如阿里云，腾讯云，或者今天有的时候那些，比如说就那个后台，就是这样，就各种OSS中心存储，就这些比较多基础都是然后每个的比如说k8s有k8s的问题，然后您包括您应该帮我印象也提到了 Minio 的问题。OSS的问题其实每一个都是往深说的话，他就是每一个都有每一个特别个性的自己的安全。然后您刚提到那两个工具，我不太了解，说实话。
    Q：好吧，因为我在学那个，因为我在写这个。就是我第二个项目不是写waf的，当时正好学习一下购语言去去练手这个 waf 因为我当时就了解到他们国外的，他们这个，就是云上

的一个安全，他们就是用的这个 Falco 比较多。因为它好像是底层是走的 eBPF，然后我就是用了一个类似于运行时的一个运行 RASP 这样的一个思想去做的。就是想了解一下，因为您这边是云云业务，就是想可能实际上获取会涉及到这个，就是想了解一下，就是我想知道它真实企业它的一个场景。

A：您说的这个东西，说实话我确实不是特别了解的话，但 RASP 有一定的了解。

17. 反问 Q：好的，其他的话我就想还有我不知道您对我这次面试的大概是有什么见解，就是我可能需要哪些地方还需要提高的。

    A：暂时没有。

18. 反问 Q：好的，然后最后一个问题就是我想请问一下，如果是如果面试通过二面的话，大概可能会问一些哪些方向呢？

    A：这个的话一般就是安慰的话会到我们的部门领导，部门领导的话可能会关心一些更宏观的角度。比如说您一个项目或者说有一些什么事，然后你如何去处理，可能是类似的，对技术方面可能会不会聊的太深。